

OWASP: Seguridad de Aplicaciones

Proyecto, aportes, estándares y herramientas para el desarrollo seguro

TOP 10

ASVS

ZAP

DEVSECOPS

Introducción

Top 10

Herramientas

DevSecOps

Siguiente ►

¿Qué es OWASP?

Open Worldwide Application Security Project

Una comunidad global

- Fundación y comunidad sin ánimo de lucro
- Enfocada en mejorar la seguridad del software
- Conocimiento, estándares y herramientas abiertas
- Orientada a desarrolladores, arquitectos, DevOps y equipos de seguridad

Idea central

OWASP ayuda a responder:

- ¿Qué vulnerabilidades existen?
- ¿Cómo prevenirlas?
- ¿Cómo detectarlas?
- ¿Cómo integrar seguridad durante todo el ciclo de vida?

Los principales aportes de OWASP

Top 10

Concienciación sobre riesgos críticos

ASVS

Requisitos verificables de seguridad

SAMM

Madurez de seguridad organizacional

WSTG

Metodología de pruebas

Cheat Sheets

Buenas prácticas aplicables

Herramientas

Automatización y entrenamiento



OWASP TOP 10

Riesgos de Seguridad en Aplicaciones Web

El OWASP Top 10 es un estándar ampliamente reconocido que identifica los **10 riesgos más críticos** para la seguridad de las aplicaciones web.



OWASP Top 10

1



A01:2021 – Fallos de Control de Acceso

Ocurren cuando una aplicación no restringe adecuadamente el acceso a funcionalidades o datos sensibles.

Ejemplo: Un usuario accede a información de otro usuario modificando la URL.

2



A02:2021 – Fallos Criptográficos

Ocurren cuando la aplicación no protege adecuadamente la información sensible (en tránsito o en reposo).

Ejemplo: Transmisión de contraseñas en texto plano (sin HTTPS).

3



A03:2021 – Inyección

Ocurre cuando datos no confiables son enviados a un intérprete como parte de un comando o consulta.

Ejemplo: SQL Injection, NoSQL Injection, Command Injection, etc.

4



A04:2021 – Diseño Inseguro

Riesgos relacionados con fallos en el diseño de la arquitectura o la lógica de negocio de la aplicación.

Ejemplo: Funcionalidades inseguras por falta de validaciones o controles.

5



A05:2021 – Configuración de Seguridad Incorrecta

Configuraciones inseguras por defecto o mal configuradas pueden exponer la aplicación y su infraestructura.

Ejemplo: Directorios listables, servicios innecesarios habilitados, contraseñas por defecto.

6



A06:2021 – Componentes con Vulnerabilidades Conocidas

Uso de componentes (librerías, frameworks, plugins) con vulnerabilidades conocidas que pueden ser explotadas.

Ejemplo: Una librería desactualizada con una vulnerabilidad publicada.

7



A07:2021 – Fallos de Identificación y Autenticación

Permiten a atacantes comprometer cuentas de usuario o suplantar identidades.

Ejemplo: Contraseñas débiles o falta de autenticación multifactor (MFA).

8



A08:2021 – Fallos de Integridad del Software y Datos

Ocurren cuando el software o los datos pueden ser modificados de manera no autorizada.

Ejemplo: Actualizaciones sin verificación de integridad o descarga de código no confiable.

9



A09:2021 – Fallos en el Registro y Monitoreo

La falta de registros y monitoreo adecuados impide detectar, responder y recuperarse de ataques.

Ejemplo: No registrar intentos de inicio de sesión fallidos o errores críticos.

10



A10:2021 – Falsificación de Solicitudes del Lado del Servidor (SSRF)

Permite a atacantes forzar al servidor a realizar solicitudes a destinos internos o externos.

Ejemplo: El servidor accede a servicios internos no expuestos públicamente.



RECOMENDACIONES GENERALES

- ✓ Aplicar el principio de defensa en profundidad.
- ✓ Mantener dependencias y componentes actualizados.
- ✓ Validar todas las entradas y manejar errores correctamente.
- ✓ Implementar autenticación y autorización robustas.
- ✓ Monitorear, registrar y responder a incidentes.



¿POR QUÉ ES IMPORTANTE?

Abordar estos riesgos reduce significativamente la superficie de ataque y protege los datos, la reputación y la confianza de los usuarios.

Más información: <https://owasp.org/www-project-top-ten/>

Inicio

Siguiente ►



ASVS y SAMM

Dos aportes complementarios

OWASP ASVS

Define requisitos de seguridad verificables.

Útil para:

- Arquitectura
- Desarrollo
- Auditorías
- Pentesting
- DevSecOps
- Revisión de código

OWASP SAMM

Evalúa la madurez de la seguridad en el desarrollo.

Evolución típica:

Inicial → Controles básicos → Pruebas →
Automatización → DevSecOps → Mejora continua

WSTG: Web Security Testing Guide

Una metodología para evaluar aplicaciones web

Configuración

Área de evaluación

Autenticación

Área de evaluación

Gestión de sesiones

Área de evaluación

Autorización

Área de evaluación

Validación de entradas

Área de evaluación

Criptografía

Área de evaluación

Lógica de negocio

Área de evaluación

APIs

Área de evaluación

Inicio

Siguiente ►

Herramientas OWASP

De la evaluación a la automatización

ZAP

DAST y proxy de pruebas

Dependency-Check

Dependencias vulnerables

Dependency-Track

Riesgo de componentes

CycloneDX

SBOM

Threat Dragon

Threat Modeling

Amass

Superficie de ataque

Juice Shop

Entrenamiento

WebGoat

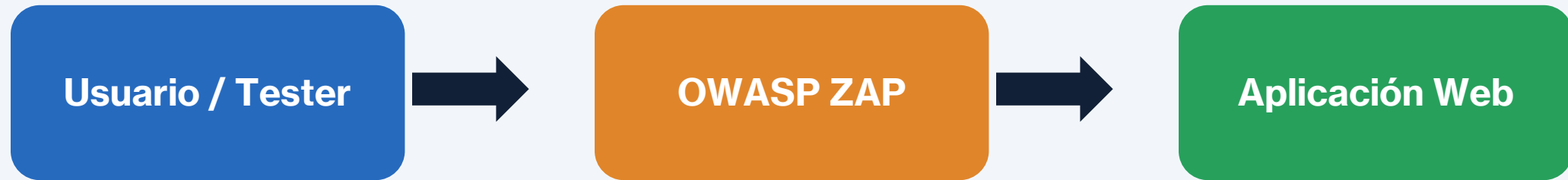
Laboratorios

Inicio

Siguiente ►

OWASP ZAP

Zed Attack Proxy: pruebas dinámicas de aplicaciones



Usos principales

Proxy de interceptación • Análisis automatizado • Detección de vulnerabilidades • DAST • Integración CI/CD

Seguridad de dependencias y cadena de suministro

Dependency-Check

Detecta componentes con vulnerabilidades conocidas

Relevante en:

- Open Source
- Microservicios
- Contenedores
- Cloud

Dependency-Track

Gestiona riesgos de componentes

Relevante en:

- Open Source
- Microservicios
- Contenedores
- Cloud

CycloneDX

Genera y utiliza SBOM

Relevante en:

- Open Source
- Microservicios
- Contenedores
- Cloud

Aprender haciendo

Laboratorios deliberadamente vulnerables

OWASP Juice Shop

Aplicación moderna vulnerable para:

- Entrenamiento
- CTF
- Pruebas de herramientas
- DevSecOps
- Ethical Hacking

OWASP WebGoat

Aprendizaje guiado:

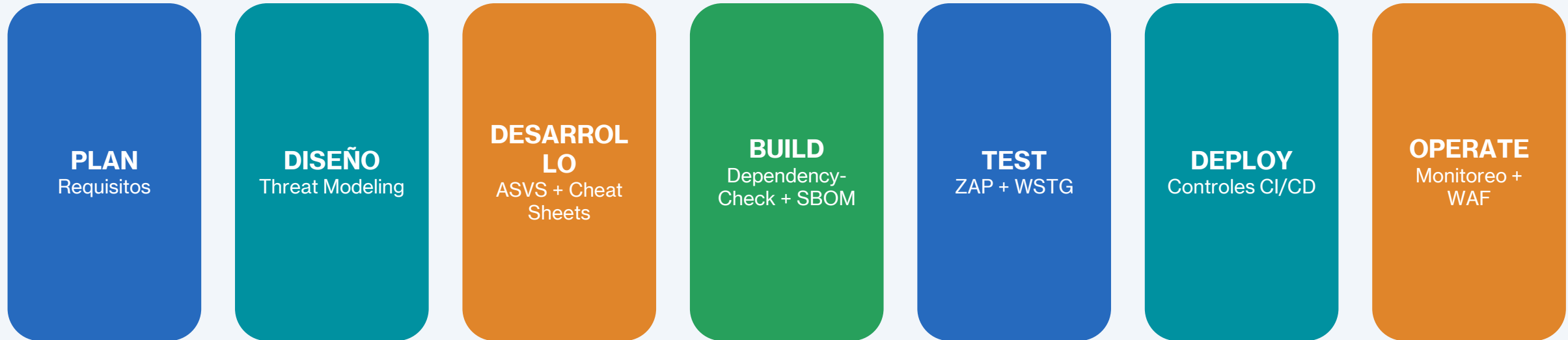
Concepto → Vulnerabilidad → Ejercicio →
Ataque controlado → Explicación → Mitigación

Inicio

Siguiente ►

OWASP dentro de DevSecOps

Seguridad integrada en todo el ciclo de vida



Inicio

Siguiente ►

Conclusión

OWASP como ecosistema de seguridad de aplicaciones

OWASP no es solo el Top 10

Es un ecosistema abierto de conocimiento, estándares, metodologías, herramientas y laboratorios.

Qué proteger
Top 10

Cómo verificar
ASVS + WSTG

Cómo madurar
SAMM

**Cómo
automatizar**
ZAP + SCA + SBOM

**Cómo
aprender**
Juice Shop + WebGoat